Saudi GRC Platform

Implementation Backlog

Source: `implementation-backlog.md`

12 — Implementation Backlog

Agile backlog grouped by epic. Status reflects the platform at HEAD. Stories not marked DONE are recommended next-sprint work.

Statuses: **DONE** ✓ shipped · **IN_PROGRESS** ■ partly shipped · **PLANNED** ■

EPIC 1 — Foundation Platform ✓ DONE

Story	Priority	Status	Notes
F1.1 Multi-tenant Organisation model with TenantContext	P0	✓	platform/tenant/
F1.2 Bilingual EN/AR shell with RTL/LTR auto-switch	P0	✓	lib/i18n.tsx
F1.3 JWT auth + refresh + MFA	P0	✓	module/auth/
F1.4 IAM (users, roles, permissions, SSO/Nafath)	P0	✓	module/iam/
F1.5 Audit log + realtime broadcaster	P0	✓	platform/audit/ + STOMP
F1.6 Soft-delete + audit on every entity (BaseEntity)	P0	✓	enforced via @Where
F1.7 White-label / branding	P1	✓	lib/whiteLabel.ts

Acceptance: any new module inherits tenant + audit + soft-delete for free. ✓ verified across 17 backend modules.

EPIC 2 — Regulatory Library ✓ DONE

Story	Priority	Status
F2.1 Framework catalogue (NCA + SAMA + ISO + PCI)	P0	✓ V37
F2.2 Control library (145 controls)	P0	✓ V42-44, V49
F2.3 Requirement → control crosswalk	P0	✓
F2.4 Per-tenant applicability	P0	✓
F2.5 Regulatory change feed	P1	✓ compliance/regulatory-change/

EPIC 3 — Workflow Engine ✓ DONE

Story	Priority	Status
F3.1 State-machine service pattern with IllegalTransitionException	P0	✓
F3.2 Workflow versioning DRAFT→ACTIVE→DEPRECATED	P0	✓
F3.3 Workflow designer UI	P1	✓ WorkflowDesigner.tsx

Story	Priority	Status
F3.4 SLA timers + escalations	P0	✓
F3.5 Approval matrix per workflow	P0	✓

EPIC 4 — Evidence Repository ✓ DONE

Story	Priority	Status
F4.1 Evidence items + versions + links	P0	✓
F4.2 SHA-256 chain-of-custody (V47)	P0	✓
F4.3 Bilingual evidence catalogue	P0	✓
F4.4 Per-tenant permissions	P0	✓
F4.5 Expiry + renewal workflow	P1	✓

EPIC 5 — ERM ✓ DONE

Story	Priority	Status
F5.1 Risk register + assessment + treatment	P0	✓
F5.2 Appetite + breach feed	P0	✓
F5.3 KRI definitions + breach events	P0	✓
F5.4 Scenario analysis (Monte Carlo + stress + what-if)	P0	✓ V35
F5.5 Emerging risk (horizon-scan)	P0	✓ V39
F5.6 Committee workflows	P0	✓ V40
F5.7 Risk acceptance with digital signature	P0	✓
F5.8 Lessons-learned integration	P1	✓

EPIC 6 — BCM ✓ DONE

Story	Priority	Status
F6.1 Critical services + BIA	P0	✓
F6.2 BCP builder	P0	✓
F6.3 IT DRP with site type + failover/failback steps	P0	✓ V41
F6.4 Exercise programme	P0	✓
F6.5 Crisis activation + comms templates	P0	✓
F6.6 Dependency map	P0	✓
F6.7 Lessons learned	P1	✓

EPIC 7 — Supply Chain Resilience ✓ DONE

Story	Priority	Status
F7.1 Vendor register + criticality + assessment	P0	✓
F7.2 Alternate supplier + exit plan	P0	✓ V36
F7.3 Supplier resilience tests	P0	✓ V54
F7.4 Fourth-party exposure + concentration risk	P0	✓ V50
F7.5 Contract clause library	P0	✓ V45
F7.6 SLA monitoring	P1	✓
F7.7 Consolidated TPRM overview	P1	✓ (component)

EPIC 8 — NCA Compliance ✓ DONE

Story	Priority	Status
F8.1 ECC framework + 30 seeded controls	P0	✓
F8.2 CSCC + 32 controls	P0	✓ V42
F8.3 CCC + 30 controls	P0	✓ V43
F8.4 OTCC + 27 controls	P0	✓ V44
F8.5 SAMA + ISO 22301 + PCI DSS seeds	P0	✓ V49
F8.6 NCA self-assessment + filing	P0	✓
F8.7 Cyber incident NIST 800-61 lifecycle	P0	✓
F8.8 RCA with CAPA generation	P0	✓ V31

EPIC 9 — PDPL Compliance ✓ DONE

Story	Priority	Status
F9.1 ROPA register	P0	✓
F9.2 Privacy notices	P0	✓ V32
F9.3 Consent	P0	✓
F9.4 DSR (30-day SLA)	P0	✓
F9.5 PIA	P0	✓
F9.6 Personal data breach (72h timer)	P0	✓
F9.7 Cross-border transfer	P0	✓ V32
F9.8 Disposal certificate	P0	✓ V32
F9.9 Data sharing agreement	P0	✓ V51
F9.10 Processor due diligence (Art. 28)	P0	✓ V52

Story	Priority	Status
F9.11 Cyber→PDPL bridge automation	P0	✓ V46

EPIC 10 — Incident & Crisis ✓ DONE

Story	Priority	Status
F10.1 Incident lifecycle (NIST 800-61)	P0	✓
F10.2 Crisis activation	P0	✓
F10.3 Regulator notification routing	P0	✓
F10.4 RCA + CAPA wiring	P0	✓ V31
F10.5 Lessons learned	P1	✓

EPIC 11 — Reporting & Dashboards ✓ DONE

Story	Priority	Status
F11.1 Customisable dashboard with widgets	P0	✓
F11.2 Board pack PDF + PPTX	P0	✓
F11.3 Scheduled reports	P1	✓
F11.4 Per-regulator evidence pack export	P0	✓
F11.5 TPRM snapshot widget	P1	✓ (this doc set)

EPIC 12 — Digital Signature ✓ DONE

Story	Priority	Status
F12.1 Signature transactions	P0	✓ V30
F12.2 Provider-pluggable (internal/DocuSign/Absher/Nafath)	P1	✓
F12.3 SHA-256 payload binding	P0	✓
F12.4 Inbox + history	P0	✓

EPIC 13 — Administration & Workflow Config ✓ DONE

Story	Priority	Status
F13.1 Tenant management	P0	✓
F13.2 User + role + permission management	P0	✓
F13.3 Committees	P0	✓ V40
F13.4 Notification channels + outbox	P0	✓
F13.5 Workflow versioning UI	P1	✓

Story	Priority	Status
F13.6 White-label	P1	✓

EPIC 14 — API & Integration Layer ✓ DONE

Story	Priority	Status
F14.1 OpenAPI/Swagger at /swagger-ui.html	P0	✓
F14.2 Connectors (intake, vendor, regulator feeds)	P1	✓
F14.3 Realtime broadcaster (STOMP/WS)	P0	✓
F14.4 Webhook outbox	P1	✓

EPIC 15 — Bilingual AR/EN UI ✓ DONE

Story	Priority	Status
F15.1 EN + AR dictionaries with parallel keys	P0	✓
F15.2 RTL CSS + logical properties	P0	✓
F15.3 Hijri calendar surface	P1	✓ HijriDate.tsx
F15.4 Saudi-native Arabic phrasing	P1	✓ (this doc set)
F15.5 PDF/PPTX bilingual templates	P0	✓

EPIC 16 — TPRM Automation (this doc set) ✓ DONE

Story	Priority	Status
F16.1 Auto-CAPA on processor FAIL	P0	✓
F16.2 Auto-CAPA on fourth-party HIGH concentration	P0	✓
F16.3 Auto-CAPA on resilience-test FAIL	P0	✓
F16.4 Cross-module link chips	P1	✓
F16.5 Consolidated /tprm overview	P0	✓
F16.6 Dashboard TPRM snapshot widget	P1	✓

Sprint grouping (post-shipment recommendations)

Sprint 7 — Operate & Tune

- Hardening pass on the 50+ NVARCHAR columns that previously had mojibake (write a Flyway migration that re-asserts canonical Arabic literals).

- Auto-CAPA noise tuning (suppression for already-known issues).
- Saudi-native Arabic polish pass on remaining ~2,000 keys.
- Performance budget: page LCP < 2s on cold load.

Sprint 8 — AI Governance

- AI register (similar to ROPA, per AI use-case).
- LLM provider DD (extension of Processor Assessment).
- Bias / fairness audit workflow.

Sprint 9 — ESG / Vision 2030 alignment

- ESG framework seeds.
- Vision-2030 KPI overlay on dashboard.
- Saudization (Nitaqat) deeper integration.

Sprint 10 — Advanced analytics

- Time-series KPI store.
- Forecasting (e.g. CAPA backlog burn-down).
- Multi-tenant benchmarking (anonymised).